Project Design Phase

Script-Controlled ACL - Restrict Record Access Based on Field Value

ServiceNow Platform

Project Title	Script-Controlled ACL - Restrict Record Access Based on Field Value
Platform	ServiceNow (Table, Roles, ACL)
Team Size	5 Members
Lab Duration	3 hrs
Phase	3. Project Design Phase

Team Members

Member	Name	Role
Member 1	Swetha V	Team Lead
Member 2	Vaitheeshwari S	Requirements
Member 3	Swetha T	Table, Fields, Data
Member 4	Abinesh V	Users, Roles, ACL Scripts
Member 5	Anbuselvam M	Test Cases

1. Solution Overview

The design uses four ACL records on one custom table. Each ACL is an *Allow If* rule that requires a specific custom role. The READ ACL is additionally **advanced**: it has a data condition (Branch is EEE) and a script that checks the user's role.

2. High-Level Access Flow

Step	What happens
1	User opens the list u_institution_details.list.
2	ServiceNow finds the READ ACL for the table.
3	Role check: does the user have bb1?
4	Data condition: is Branch = EEE for this record?
5	Script runs: admin returns true; bb1 returns true; everyone else returns false.
6	If all conditions pass, the record is shown; otherwise it is hidden.

3. Data Model

Table label: **Institution Details** | Table name: **u_institution_details** | Extends: none (false).

Field	Type	Reference / Values
Student Roll Number	String (Auto Number)	Default: getNextObjNumberPadded()
Student Name	Reference	sys_user

Faculty Name	Reference	sys_user
Branch	Choice	ECE / EEE / CSE
Email	String	-
Phone Number	String	-
Description	Multi-line String	-

4. Role and ACL Design Matrix

ACL	Operation	Table	Required Role	Data Condition	Advanced Script
ACL-1	read	u_institution_details	bb1	Branch is EEE	Yes
ACL-2	create	u_institution_details	bb2	None	No
ACL-3	write	u_institution_details	bb3	None	No
ACL-4	delete	u_institution_details	bb4	None	No

5. Cumulative Permission Design

Roles Held by User	Effective Access
None	No records visible
bb1	View EEE records only
bb1 + bb2	View EEE records + New button
bb1 + bb2 + bb3	View, create and edit EEE records
bb1 + bb2 + bb3 + bb4	View, create, edit and delete EEE records
admin	Full access to all records

6. ACL Script Design (READ ACL)

The script keeps the logic simple: admin bypass, role check, then deny by default. The branch filtering itself is handled by the ACL data condition, so the script does not need to query the database.

```
(function () {   // Allow admin users full access
if (gs.hasRole('admin')) {     return true;   }   //
Allow only users with role bb1 (EEE branch users)
if (gs.hasRole('bb1')) {     return true;   }   //
Deny access for all others   return false; })();
```

7. Security Design Principles Applied

- **Least privilege:** separate roles for read, create, write and delete.
- **Deny by default:** script ends with return false.
- **Server-side enforcement:** ACLs apply to lists, forms and API access.
- **Admin override:** administrators retain full access for support.

8. Test Users Design

User	Roles	Purpose
EEE User	bb1, bb2, bb3, bb4	Main test user (EEE branch)
Any other user	No custom role	Negative test
System Administrator	admin, security_admin	Full-access check